

From Edge AI to Governed Autonomous Edge Intelligence: SGAEIA, a Security-by-Design Reference Architecture for Distributed Multi-Agent Systems

Aridio Silva
@aridiosilva
Independent Researcher
<https://github.com/aridiosilva/SGAEIA>

September 2026

Abstract

Edge computing moved computation toward data sources; Edge AI moved inference and learning toward the network edge; generative and agentic AI now move planning, tool use, delegation, memory, and action toward the edge. This paper argues that the resulting transition is not merely from centralized to distributed intelligence, but from distributed intelligence to distributed agency and authority. We present SGAEIA (Secure Governed Autonomous Edge Intelligence Architecture), an open, vendor-neutral reference architecture and Spec-Driven Development framework for bounded, revocable, observable, and continuously governed multi-agent Edge AI. SGAEIA combines workload identity, capability and delegation graphs, Agent Trust Zones, risk-adaptive autonomy, policy decision/enforcement separation, continuous GRC, evidence-as-code, formal security invariants, replaceable integration ports, and adapter conformance. The accompanying reference implementation provides executable specifications and tests. We explicitly distinguish designed properties, formally specified properties, locally tested properties, and properties requiring future live-system evaluation.

Project: SGAEIA — Secure Governed Autonomous Edge Intelligence Architecture.

1 Introduction

Edge computing emerged to address latency, bandwidth, locality, privacy, and resilience constraints that cloud-only architectures cannot always satisfy [1]. Edge intelligence extended this paradigm by moving AI inference and training toward devices and edge infrastructure [2, 3]. ETSI MEC reflects the continuing operational maturation of edge infrastructure [12].

Agentic AI introduces a qualitatively different transition. Agents may plan, use memory and retrieval, invoke tools, collaborate, delegate, and affect digital or physical systems. Multi-agent research already demonstrates diverse collaboration structures and protocols [15]. The security boundary therefore expands from distributed computation to distributed authority.

We summarize the evolution as:

Cloud Computing → *Edge Computing* → *Edge Intelligence* → *Distributed Autonomous Agency*.

The research question is: *how can heterogeneous, distributed, intermittently connected multi-agent Edge AI support useful autonomy without allowing authority, delegation, trust, and evidence to become implicit or unbounded?*

SGAEIA’s central thesis is that distributed intelligence does not require distributed implicit trust. Autonomy can be decentralized while authority remains explicit, bounded, auditable, and revocable.

2 From Edge AI to Distributed Authority

Traditional Edge AI commonly centers on placement and optimization of prediction or learning workloads [2]. Agentic Edge AI changes the unit of control from a model invocation to an authority-bearing actor. A useful abstraction is

$$Agent = Model + State + Memory + Tools + PolicyContext + Identity.$$

An agent may read or modify data, call APIs, execute tools, create or delegate tasks, and interact with cyber-physical systems. Hence:

$$Distributed\ Intelligence \neq Distributed\ Trust \neq Unbounded\ Authority.$$

This distinction motivates explicit governance of non-human identities, capabilities, delegation, and action.

3 Threat Model

The model assumes untrusted external input, prompt/tool injection, compromised agents, poisoned retrieval or memory, malicious or over-privileged tools, identity theft, policy bypass, delegation escalation, autonomous lateral movement, evidence suppression, network partition, supply-chain compromise, and unsafe actuation. Agentic-security literature emphasizes that tool use, memory, autonomy, and long-horizon action create risks beyond conventional model inference [16]. MITRE ATLAS and OWASP agentic guidance provide complementary threat taxonomies [9, 10].

4 Formal System Model

A governed deployment is modeled as

$$S = (V, E, Z, P, I, C, R, T, L),$$

where V denotes entities, E relations, Z trust zones, P policies, I identities, C capabilities, R risks, T telemetry/evidence, and L lifecycle state. A governed agent satisfies

$$Governed(A) = Identity \wedge Owner \wedge Purpose \wedge Capabilities \wedge Policy \wedge Risk \wedge Observability \wedge Auditability \wedge Revocability$$

5 Governed Autonomy

SGAEIA separates criticality classes L0–L4 from autonomy levels A0–A5. L4 denotes cyber-physical/safety-critical contexts; A5 denotes autonomous orchestration/delegation. The reference profile prohibits L4+A5. Effective autonomy is

$$A_{effective} = \min(A_{configured}, A_{risk}, A_{context}, A_{trust}, A_{policy}).$$

Agent Trust Zones range from ATZ-0 (external/unknown) through ATZ-5 (cyber-physical critical). ATZ-5 means maximum control requirement, not implicit trust.

6 Identity, Capability, and Delegation

Each governed agent is treated as a non-human identity. SPIFFE illustrates portable workload-bound cryptographic identity through SPIFFE IDs, SVIDs, and a Workload API [11]. Authorization requires more than identity:

Authorize = IdentityValid ∧ CapabilityValid ∧ PolicyAllows ∧ Risk < MaxRisk ∧ Trust > MinTrust.

Delegation is bounded by capability subset, maximum depth, expiry, resource, purpose, and context constraints.

7 Zero-Trust Policy Enforcement

The runtime control path is:

Intent → Identity → Capability → Delegation → Risk → PDP → PEP → Approval → Execution → Evidence

The model is not the security authority. The agent proposes; an external policy architecture authorizes or denies. This is consistent with zero-trust principles that reject implicit trust based on network location [4, 5].

8 Continuous GRC and Evidence-as-Code

NIST AI RMF and the GenAI Profile provide lifecycle risk-management foundations [6, 7]. SGAEIA connects governance to runtime through

Regulation → Requirement → Risk → Control → Policy → Enforcement → Evidence.

Critical actions produce correlated provenance containing identity, intent, policy decision, risk score, delegation chain, tool call, approval, outcome, timestamp, and integrity metadata.

9 Security-by-Design and SDD

Security is specified before implementation:

Requirement → Threat/Risk → Control → Policy → Implementation → Test → Evidence.

This makes Security-by-Design, Security-First, and Shift-Left/Right/Everywhere concrete rather than aspirational. NIST secure-development guidance for generative AI informs this lifecycle [8].

10 Integration Ports and Adapter Conformance

Vendor neutrality is semantic. A replacement technology is conformant only if it preserves

Functional ∧ Security ∧ Audit ∧ Failure ∧ Revocation.

Ports cover identity, PDP, PEP, risk, registry, evidence, kill switch, observability, event bus, mesh, state, and edge orchestration. OpenAPI and AsyncAPI are used where appropriate [13, 14]. The Adapter Conformance Framework separates local contract compatibility from representative/live assurance.

11 Formal Invariants

Representative invariants include:

$$\begin{aligned} AgentWithoutIdentity &\Rightarrow DENY \\ UnknownAgent &\Rightarrow DENY \\ L4 \wedge A5 &\Rightarrow DENY \\ DelegationDepth > MaxDepth &\Rightarrow DENY \\ ChildCapabilities \not\subseteq ParentDelegatedCapabilities &\Rightarrow DENY \\ OfflineMode &\Rightarrow ReducedOrEqualAuthority. \end{aligned}$$

The repository includes TLA+ and Alloy specifications, but this paper does not claim that external TLA+/Alloy model checkers have been executed. Equivalent selected finite-state properties are exercised by Python tests.

12 Reference Implementation and Evidence

The public Python reference implementation includes manifests, registries, risk scoring, delegation checks, kill-switch behavior, evidence generation, policies, OpenAPI/AsyncAPI contracts, formal specifications, and adapter profiles. At manuscript preparation time, local validation reported 31 passing tests and nine adapter profiles in the contract harness. These are repository-level results only; they do not establish production security, performance, or safety.

13 Evaluation Agenda

Future evaluation should measure unauthorized-action prevention, behavior during network/control-plane partition, revocation propagation latency, policy and telemetry overhead, evidence completeness, semantic equivalence under adapter replacement, and independent reproducibility. A cyber-range protocol is provided as a separate SGAEIA technical manuscript.

14 Limitations

SGAEIA is a reference architecture, not a certified product. Risk thresholds are illustrative; safety-critical deployment requires domain-specific hazard analysis and independent safety mechanisms. Local adapter tests do not certify upstream products. Formal abstractions do not prove completeness of the threat model.

15 Conclusion

Edge computing created distributed computation; Edge AI created distributed intelligence; agentic Edge AI introduces distributed agency and authority. SGAEIA addresses the resulting need for autonomy that is bounded, revocable, observable, policy-mediated, and continuously governed. Intelligence may be distributed; authority must remain explicitly governed.

Availability

Open reference implementation and specifications: <https://github.com/aridiosilva/SGAEIA>.

References

- [1] W. Shi et al., “Edge Computing: Vision and Challenges,” *IEEE Internet of Things Journal*, 3(5), 637–646, 2016. doi:10.1109/JIOT.2016.2579198.
- [2] Z. Zhou et al., “Edge Intelligence: Paving the Last Mile of Artificial Intelligence With Edge Computing,” *Proceedings of the IEEE*, 107(8), 1738–1762, 2019. doi:10.1109/JPROC.2019.2918951.
- [3] E. Li, Z. Zhou, X. Chen, “Edge Intelligence: On-Demand Deep Learning Model Co-Inference with Device-Edge Synergy,” *MECOMM*, 2018. doi:10.1145/3229556.3229562.
- [4] NIST, Zero Trust Architecture, SP 800-207, 2020. doi:10.6028/NIST.SP.800-207.
- [5] NIST, A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments, SP 800-207A, 2023. doi:10.6028/NIST.SP.800-207A.
- [6] NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), AI 100-1, 2023. doi:10.6028/NIST.AI.100-1.
- [7] C. Autio et al., Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, 2024. doi:10.6028/NIST.AI.600-1.
- [8] NIST, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models, SP 800-218A, 2024.
- [9] MITRE, ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems, <https://atlas.mitre.org/>, accessed Sep. 2026.
- [10] OWASP GenAI Security Project, Agentic Security Initiative and Agent Control Standard, <https://genai.owasp.org/>, accessed Sep. 2026.
- [11] SPIFFE Project, The SPIFFE Standard, <https://spiffe.io/docs/latest/spiffe-specs/>, accessed Sep. 2026.
- [12] ETSI, Multi-access Edge Computing (MEC), <https://www.etsi.org/technical-groups/mec/>, accessed Sep. 2026.
- [13] OpenAPI Initiative, OpenAPI Specification 3.2.0, 2025.
- [14] AsyncAPI Initiative, AsyncAPI Specification 3.1.0, 2026.
- [15] K.-T. Tran et al., “Multi-Agent Collaboration Mechanisms: A Survey of LLMs,” *arXiv:2501.06322*, 2025.
- [16] S. Datta et al., “Agentic AI Security: Threats, Defenses, Evaluation, and Open Challenges,” *arXiv:2510.23883*, 2025.